PandaX Developer validation report

69 of 76 named checks matched. Seven expected findings were missed.

14 input scans completed; all 14 seals verified. Four built-in comparison actions passed. Positive checks: 35/42 found. Negative checks: 34/34 correctly absent.

Scope: the freshly pulled local dashboard at engine revision d7f7890, tested through its HTTP endpoints on 7 September 2026. A separate hosted deployment was not verified. No exploit or runtime reachability testing was performed.

How to read this report

HIT = expected vulnerable component/CVE was found. MISS = expected finding was absent. CORRECT ABSENCE = selected fixed or excluded CVE was absent. UNGRADED = an additional reported CVE outside the selected answer key; it is not automatically a false positive.

The companion Independent Expected Results PDF is the frozen, online-source answer key. This document adds observed output. The ZIP includes every reported finding, raw evidence and the detailed root-cause report.

Result	Count
Expected affected-library findings found	35 / 42
Expected affected-library findings missed	7 / 42
Named negative controls correctly absent	34 / 34
Total observed component/CVE rows	407
Execution failures	0 / 14

Passing the built-in demo checks does not establish complete vulnerability coverage. The reference is a selected acceptance set, not an exhaustive CVE catalog.

Why the misses happened

Inventory succeeded; vulnerability discovery was incomplete.

The exact generic package identifiers for curl/libcurl and OpenSSL/libssl returned no candidates from OSV. PandaX then supplemented only the original SOCKS5 and Heartbleed demo CVEs. It has no native rules for the four missed CVEs.

Affected releases	Missing CVE	Vendor fix
libcurl 8.3.0	CVE-2023-38546	8.4.0
libcurl 8.3.0 and 8.4.0	CVE-2023-46218	8.5.0
libssl 1.0.1f and 1.0.1g	CVE-2014-0224	1.0.1h
libssl 1.0.1f and 1.0.1g	CVE-2014-0195	1.0.1h

What the diagnostic requests proved

All four CVEs exist in OSV. Git-tag queries discovered the two curl CVEs, but not the two OpenSSL CVEs. The direct OpenSSL records contain no affected-package/range entries. There is no evidence that triage suppressed returned findings.

A fallback also needs conflict handling: OSV lists curl 8.4.0 as affected by CVE-2023-38546, contrary to the vendor-fixed boundary. The diagnostic Git result is not an original PandaX false positive.

Developer priorities

1. Add source-aware native discovery and vendor fix evidence. 2. Distinguish no returned candidates from established coverage. 3. Preserve negative controls when resolving feed conflicts. 4. Separate affected-library status from proven exploitability. 5. Keep the independent acceptance tests outside the demo rules.

See reports/PandaX_Root_Cause_Report.md and raw root-cause-evidence JSON for requests, responses and source-code locations. No scanner fix was applied in this investigation.

OpenWrt 19.07.0

HITS 3/3 | CORRECT ABSENCES 5/5 | REPORTED ROWS 4

Scan completed and seal verified. All selected expected inventory entries were present.

Component / CVE	Expected	Observed	Result
libubox CVE-2020-7248	Affected	FOUND	HIT
dnsmasq CVE-2020-25681	Excluded	NOT FOUND	CORRECT ABSENCE
dnsmasq CVE-2020-25682	Excluded	NOT FOUND	CORRECT ABSENCE
dnsmasq CVE-2020-25683	Excluded	NOT FOUND	CORRECT ABSENCE
dnsmasq CVE-2020-25684	Affected	FOUND	HIT
dnsmasq CVE-2020-25685	Excluded	NOT FOUND	CORRECT ABSENCE
dnsmasq CVE-2020-25686	Affected	FOUND	HIT
dnsmasq CVE-2020-25687	Excluded	NOT FOUND	CORRECT ABSENCE

Applicability and comparison notes

CVE-2020-7248: Fixed from OpenWrt 19.07.1. Associate the library with ubus, rpcd and uhttpd without claiming a proven runtime call path.

CVE-2020-25681: Standard dnsmasq variant: vendor excludes this CVE.

CVE-2020-25682: Standard dnsmasq variant: vendor excludes this CVE.

CVE-2020-25683: Standard dnsmasq variant: vendor excludes this CVE.

CVE-2020-25684: Affected before package revision 2.80-16.2; the upstream 2.80 number alone is insufficient.

CVE-2020-25685: Standard dnsmasq variant: vendor excludes this CVE.

CVE-2020-25686: Affected before package revision 2.80-16.2; the upstream 2.80 number alone is insufficient.

CVE-2020-25687: Standard dnsmasq variant: vendor excludes this CVE.

All reported findings (including ungraded extras): cases/openwrt-19.07.0/all-findings.csv. Raw SBOM, findings, VEX and signed output files are in evidence/bundles/run-20260907-152801-699414-06e250/ in the ZIP.

Public sources (click IDs; full titles in the independent PDF): W1, W2

OpenWrt 19.07.1

HITS 2/2 | CORRECT ABSENCES 6/6 | REPORTED ROWS 2

Scan completed and seal verified. All selected expected inventory entries were present.

Component / CVE	Expected	Observed	Result
libubox CVE-2020-7248	Fixed	NOT FOUND	CORRECT ABSENCE
dnsmasq CVE-2020-25681	Excluded	NOT FOUND	CORRECT ABSENCE
dnsmasq CVE-2020-25682	Excluded	NOT FOUND	CORRECT ABSENCE
dnsmasq CVE-2020-25683	Excluded	NOT FOUND	CORRECT ABSENCE
dnsmasq CVE-2020-25684	Affected	FOUND	HIT
dnsmasq CVE-2020-25685	Excluded	NOT FOUND	CORRECT ABSENCE
dnsmasq CVE-2020-25686	Affected	FOUND	HIT
dnsmasq CVE-2020-25687	Excluded	NOT FOUND	CORRECT ABSENCE

Applicability and comparison notes

CVE-2020-7248: Fixed from OpenWrt 19.07.1. Associate the library with ubus, rpcd and uhttpd without claiming a proven runtime call path.

CVE-2020-25681: Standard dnsmasq variant: vendor excludes this CVE.

CVE-2020-25682: Standard dnsmasq variant: vendor excludes this CVE.

CVE-2020-25683: Standard dnsmasq variant: vendor excludes this CVE.

CVE-2020-25684: Affected before package revision 2.80-16.2; the upstream 2.80 number alone is insufficient.

CVE-2020-25685: Standard dnsmasq variant: vendor excludes this CVE.

CVE-2020-25686: Affected before package revision 2.80-16.2; the upstream 2.80 number alone is insufficient.

CVE-2020-25687: Standard dnsmasq variant: vendor excludes this CVE.

All reported findings (including ungraded extras): cases/openwrt-19.07.1/all-findings.csv. Raw SBOM, findings, VEX and signed output files are in evidence/bundles/run-20260907-152804-565489-1a8c01/ in the ZIP.

Public sources (click IDs; full titles in the independent PDF): W1, W2

OpenWrt 19.07.5

HITS 2/2 | CORRECT ABSENCES 6/6 | REPORTED ROWS 2

Scan completed and seal verified. All selected expected inventory entries were present.

Component / CVE	Expected	Observed	Result
libubox CVE-2020-7248	Fixed	NOT FOUND	CORRECT ABSENCE
dnsmasq CVE-2020-25681	Excluded	NOT FOUND	CORRECT ABSENCE
dnsmasq CVE-2020-25682	Excluded	NOT FOUND	CORRECT ABSENCE
dnsmasq CVE-2020-25683	Excluded	NOT FOUND	CORRECT ABSENCE
dnsmasq CVE-2020-25684	Affected	FOUND	HIT
dnsmasq CVE-2020-25685	Excluded	NOT FOUND	CORRECT ABSENCE
dnsmasq CVE-2020-25686	Affected	FOUND	HIT
dnsmasq CVE-2020-25687	Excluded	NOT FOUND	CORRECT ABSENCE

Applicability and comparison notes

CVE-2020-7248: Fixed from OpenWrt 19.07.1. Associate the library with ubus, rpcd and uhttpd without claiming a proven runtime call path.

CVE-2020-25681: Standard dnsmasq variant: vendor excludes this CVE.

CVE-2020-25682: Standard dnsmasq variant: vendor excludes this CVE.

CVE-2020-25683: Standard dnsmasq variant: vendor excludes this CVE.

CVE-2020-25684: Affected before package revision 2.80-16.2; the upstream 2.80 number alone is insufficient.

CVE-2020-25685: Standard dnsmasq variant: vendor excludes this CVE.

CVE-2020-25686: Affected before package revision 2.80-16.2; the upstream 2.80 number alone is insufficient.

CVE-2020-25687: Standard dnsmasq variant: vendor excludes this CVE.

All reported findings (including ungraded extras): cases/openwrt-19.07.5/all-findings.csv. Raw SBOM, findings, VEX and signed output files are in evidence/bundles/run-20260907-152807-318644-e79b2f/ in the ZIP.

Public sources (click IDs; full titles in the independent PDF): W1, W2

OpenWrt 19.07.6

HITS 0/0 | CORRECT ABSENCES 8/8 | REPORTED ROWS 0

Scan completed and seal verified. All selected expected inventory entries were present.

Component / CVE	Expected	Observed	Result
libubox CVE-2020-7248	Fixed	NOT FOUND	CORRECT ABSENCE
dnsmasq CVE-2020-25681	Excluded	NOT FOUND	CORRECT ABSENCE
dnsmasq CVE-2020-25682	Excluded	NOT FOUND	CORRECT ABSENCE
dnsmasq CVE-2020-25683	Excluded	NOT FOUND	CORRECT ABSENCE
dnsmasq CVE-2020-25684	Fixed	NOT FOUND	CORRECT ABSENCE
dnsmasq CVE-2020-25685	Excluded	NOT FOUND	CORRECT ABSENCE
dnsmasq CVE-2020-25686	Fixed	NOT FOUND	CORRECT ABSENCE
dnsmasq CVE-2020-25687	Excluded	NOT FOUND	CORRECT ABSENCE

Applicability and comparison notes

CVE-2020-7248: Fixed from OpenWrt 19.07.1. Associate the library with ubus, rpcd and uhttpd without claiming a proven runtime call path.

CVE-2020-25681: Standard dnsmasq variant: vendor excludes this CVE.

CVE-2020-25682: Standard dnsmasq variant: vendor excludes this CVE.

CVE-2020-25683: Standard dnsmasq variant: vendor excludes this CVE.

CVE-2020-25684: Affected before package revision 2.80-16.2; the upstream 2.80 number alone is insufficient.

CVE-2020-25685: Standard dnsmasq variant: vendor excludes this CVE.

CVE-2020-25686: Affected before package revision 2.80-16.2; the upstream 2.80 number alone is insufficient.

CVE-2020-25687: Standard dnsmasq variant: vendor excludes this CVE.

All reported findings (including ungraded extras): cases/openwrt-19.07.6/all-findings.csv. Raw SBOM, findings, VEX and signed output files are in evidence/bundles/run-20260907-152809-967854-a8a966/ in the ZIP.

Public sources (click IDs; full titles in the independent PDF): W1, W2

curl / libcurl 8.3.0

HITS 1/3 | CORRECT ABSENCES 1/1 | REPORTED ROWS 1

Scan completed and seal verified. All selected expected inventory entries were present.

Component / CVE	Expected	Observed	Result
libcurl CVE-2023-38545	Affected	FOUND	HIT
libcurl CVE-2023-38546	Affected	NOT FOUND	MISS
libcurl CVE-2023-46218	Affected	NOT FOUND	MISS
libcurl CVE-2023-38039	Fixed	NOT FOUND	CORRECT ABSENCE

Applicability and comparison notes

CVE-2023-38545: SOCKS5 remote DNS, hostname/buffer length and handshake conditions matter.

CVE-2023-38546: Library API path; not accessible through the curl CLI.

CVE-2023-46218: Still affected in 8.4.0. Inspect cookie use and PSL support.

CVE-2023-38039: Both selected releases contain this earlier fix.

All reported findings (including ungraded extras): cases/curl-8.3.0/all-findings.csv. Raw SBOM, findings, VEX and signed output files are in evidence/bundles/run-20260907-152819-972799-e78f87/ in the ZIP.

Public sources (click IDs; full titles in the independent PDF): C1, C2, C3, C4

curl / libcurl 8.4.0

HITS 0/1 | CORRECT ABSENCES 3/3 | REPORTED ROWS 0

Scan completed and seal verified. All selected expected inventory entries were present.

Component / CVE	Expected	Observed	Result
libcurl CVE-2023-38545	Fixed	NOT FOUND	CORRECT ABSENCE
libcurl CVE-2023-38546	Fixed	NOT FOUND	CORRECT ABSENCE
libcurl CVE-2023-46218	Affected	NOT FOUND	MISS
libcurl CVE-2023-38039	Fixed	NOT FOUND	CORRECT ABSENCE

Applicability and comparison notes

CVE-2023-38545: SOCKS5 remote DNS, hostname/buffer length and handshake conditions matter.

CVE-2023-38546: Library API path; not accessible through the curl CLI.

CVE-2023-46218: Still affected in 8.4.0. Inspect cookie use and PSL support.

CVE-2023-38039: Both selected releases contain this earlier fix.

All reported findings (including ungraded extras): cases/curl-8.4.0/all-findings.csv. Raw SBOM, findings, VEX and signed output files are in evidence/bundles/run-20260907-152830-716726-670b2d/ in the ZIP.

Public sources (click IDs; full titles in the independent PDF): C1, C2, C3, C4

OpenSSL 1.0.1f / s_server

HITS 1/3 | CORRECT ABSENCES 0/0 | REPORTED ROWS 1

Scan completed and seal verified. All selected expected inventory entries were present.

Component / CVE	Expected	Observed	Result
libssl CVE-2014-0160	Affected	FOUND	HIT
libssl CVE-2014-0224	Affected	NOT FOUND	MISS
libssl CVE-2014-0195	Affected	NOT FOUND	MISS

Applicability and comparison notes

CVE-2014-0160: Heartbeat support and the actual loaded library matter.

CVE-2014-0224: Both client and server must be vulnerable; both tested releases precede the fix.

CVE-2014-0195: Requires DTLS use. TLS-only operation does not exercise this path.

Triage discrepancy: Heartbleed VEX says exploitable while its explanation says build flags and runtime reachability remain unknown.

All reported findings (including ungraded extras): cases/openssl-1.0.1f/all-findings.csv. Raw SBOM, findings, VEX and signed output files are in evidence/bundles/run-20260907-152833-616712-f49618/ in the ZIP.

Public sources (click IDs; full titles in the independent PDF): O1, O2

OpenSSL 1.0.1g / s_server

HITS 0/2 | CORRECT ABSENCES 1/1 | REPORTED ROWS 0

Scan completed and seal verified. All selected expected inventory entries were present.

Component / CVE	Expected	Observed	Result
libssl CVE-2014-0160	Fixed	NOT FOUND	CORRECT ABSENCE
libssl CVE-2014-0224	Affected	NOT FOUND	MISS
libssl CVE-2014-0195	Affected	NOT FOUND	MISS

Applicability and comparison notes

CVE-2014-0160: Heartbeat support and the actual loaded library matter.

CVE-2014-0224: Both client and server must be vulnerable; both tested releases precede the fix.

CVE-2014-0195: Requires DTLS use. TLS-only operation does not exercise this path.

All reported findings (including ungraded extras): cases/openssl-1.0.1g/all-findings.csv. Raw SBOM, findings, VEX and signed output files are in evidence/bundles/run-20260907-152836-540736-744d95/ in the ZIP.

Public sources (click IDs; full titles in the independent PDF): O1, O2

SmartHub 2.3.1 / directory

HITS 10/10 | CORRECT ABSENCES 0/0 | REPORTED ROWS 102

Scan completed and seal verified. All selected expected inventory entries were present.

Component / CVE	Expected	Observed	Result
jquery CVE-2020-11023	Affected	FOUND	HIT
lodash CVE-2020-8203	Affected	FOUND	HIT
minimist CVE-2021-44906	Affected	FOUND	HIT
node-forge CVE-2022-24771	Affected	FOUND	HIT
pillow CVE-2021-25293	Affected	FOUND	HIT
requests CVE-2018-18074	Affected	FOUND	HIT
urllib3 CVE-2019-11324	Affected	FOUND	HIT
PyYAML CVE-2020-14343	Affected	FOUND	HIT
Jinja2 CVE-2019-10906	Affected	FOUND	HIT
log4j-core CVE-2021-44228	Affected	FOUND	HIT

Applicability and comparison notes

CVE-2020-11023: Conditional on the declared component/version being in the input.

CVE-2020-8203: Conditional on the declared component/version being in the input.

CVE-2021-44906: Conditional on the declared component/version being in the input.

CVE-2022-24771: Conditional on the declared component/version being in the input.

CVE-2021-25293: Conditional on the declared component/version being in the input.

CVE-2018-18074: Conditional on the declared component/version being in the input.

CVE-2019-11324: Conditional on the declared component/version being in the input.

CVE-2020-14343: Conditional on the declared component/version being in the input.

CVE-2019-10906: Conditional on the declared component/version being in the input.

CVE-2021-44228: Conditional on the declared component/version being in the input.

Triage discrepancy: Pillow/WebP build evidence is missing, but VEX asserts exploitable from KEV. This is unsupported certainty, not a proven false positive.

All reported findings (including ungraded extras): cases/smarthub-directory/all-findings.csv. Raw SBOM, findings, VEX and signed output files are in evidence/bundles/run-20260907-152838-836572-39b7ae/ in the ZIP.

Public sources (click IDs; full titles in the independent PDF): J1, J2, J3, J4, P1, P2, P3, P4, P5, L1

SmartHub 2.3.1 / zip

HITS 10/10 | CORRECT ABSENCES 0/0 | REPORTED ROWS 102

Scan completed and seal verified. All selected expected inventory entries were present.

Component / CVE	Expected	Observed	Result
jquery CVE-2020-11023	Affected	FOUND	HIT
lodash CVE-2020-8203	Affected	FOUND	HIT
minimist CVE-2021-44906	Affected	FOUND	HIT
node-forge CVE-2022-24771	Affected	FOUND	HIT
pillow CVE-2021-25293	Affected	FOUND	HIT
requests CVE-2018-18074	Affected	FOUND	HIT
urllib3 CVE-2019-11324	Affected	FOUND	HIT
PyYAML CVE-2020-14343	Affected	FOUND	HIT
Jinja2 CVE-2019-10906	Affected	FOUND	HIT
log4j-core CVE-2021-44228	Affected	FOUND	HIT

Applicability and comparison notes

CVE-2020-11023: Conditional on the declared component/version being in the input.

CVE-2020-8203: Conditional on the declared component/version being in the input.

CVE-2021-44906: Conditional on the declared component/version being in the input.

CVE-2022-24771: Conditional on the declared component/version being in the input.

CVE-2021-25293: Conditional on the declared component/version being in the input.

CVE-2018-18074: Conditional on the declared component/version being in the input.

CVE-2019-11324: Conditional on the declared component/version being in the input.

CVE-2020-14343: Conditional on the declared component/version being in the input.

CVE-2019-10906: Conditional on the declared component/version being in the input.

CVE-2021-44228: Conditional on the declared component/version being in the input.

Triage discrepancy: Pillow/WebP build evidence is missing, but VEX asserts exploitable from KEV. This is unsupported certainty, not a proven false positive.

All reported findings (including ungraded extras): cases/smarthub-zip/all-findings.csv. Raw SBOM, findings, VEX and signed output files are in evidence/bundles/run-20260907-152841-366774-d2000a/ in the ZIP.

Public sources (click IDs; full titles in the independent PDF): J1, J2, J3, J4, P1, P2, P3, P4, P5, L1

Struts 2.5.12 / full libraries

HITS 3/3 | CORRECT ABSENCES 0/0 | REPORTED ROWS 160

Scan completed and seal verified. All selected expected inventory entries were present.

Component / CVE	Expected	Observed	Result
struts2-core CVE-2018-11776	Affected	FOUND	HIT
struts2-core CVE-2023-50164	Affected	FOUND	HIT
struts2-rest-plugin CVE-2017-9805	Affected	FOUND	HIT

Applicability and comparison notes

CVE-2018-11776: Check namespace and alwaysSelectFullNamespace configuration.

CVE-2023-50164: Runtime applicability requires the affected file upload path.

CVE-2017-9805: REST plugin present in the full ZIP; absent from the minimum ZIPs.

All reported findings (including ungraded extras): cases/struts-2.5.12-full/all-findings.csv. Raw SBOM, findings, VEX and signed output files are in evidence/bundles/run-20260907-152843-759189-57429e/ in the ZIP.

Public sources (click IDs; full titles in the independent PDF): S2, S3, S1

Struts 2.5.12 / min libraries

HITS 2/2 | CORRECT ABSENCES 1/1 | REPORTED ROWS 22

Scan completed and seal verified. All selected expected inventory entries were present.

Component / CVE	Expected	Observed	Result
struts2-core CVE-2018-11776	Affected	FOUND	HIT
struts2-core CVE-2023-50164	Affected	FOUND	HIT
struts2-rest-plugin CVE-2017-9805	Excluded	NOT FOUND	CORRECT ABSENCE

Applicability and comparison notes

CVE-2018-11776: Check namespace and alwaysSelectFullNamespace configuration.

CVE-2023-50164: Runtime applicability requires the affected file upload path.

CVE-2017-9805: REST plugin present in the full ZIP; absent from the minimum ZIPs.

All reported findings (including ungraded extras): cases/struts-2.5.12-min/all-findings.csv. Raw SBOM, findings, VEX and signed output files are in evidence/bundles/run-20260907-152921-902815-74139e/ in the ZIP.

Public sources (click IDs; full titles in the independent PDF): S2, S3, S1

Struts 2.5.33 / min libraries

HITS 0/0 | CORRECT ABSENCES 3/3 | REPORTED ROWS 9

Scan completed and seal verified. All selected expected inventory entries were present.

Component / CVE	Expected	Observed	Result
struts2-core CVE-2018-11776	Fixed	NOT FOUND	CORRECT ABSENCE
struts2-core CVE-2023-50164	Fixed	NOT FOUND	CORRECT ABSENCE
struts2-rest-plugin CVE-2017-9805	Excluded	NOT FOUND	CORRECT ABSENCE

Applicability and comparison notes

CVE-2018-11776: Check namespace and alwaysSelectFullNamespace configuration.

CVE-2023-50164: Runtime applicability requires the affected file upload path.

CVE-2017-9805: REST plugin present in the full ZIP; absent from the minimum ZIPs.

All reported findings (including ungraded extras): cases/struts-2.5.33-min/all-findings.csv. Raw SBOM, findings, VEX and signed output files are in evidence/bundles/run-20260907-152924-088446-430a09/ in the ZIP.

Public sources (click IDs; full titles in the independent PDF): S2, S3, S1

Example web application 1.0.0 / SBOM

HITS 1/1 | CORRECT ABSENCES 0/0 | REPORTED ROWS 2

Scan completed and seal verified. All selected expected inventory entries were present.

Component / CVE	Expected	Observed	Result
jquery CVE-2020-11023	Affected	FOUND	HIT

Applicability and comparison notes

CVE-2020-11023: jQuery 3.4.0 is within the public affected range.

All reported findings (including ungraded extras): cases/example-sbom/all-findings.csv. Raw SBOM, findings, VEX and signed output files are in evidence/bundles/run-20260907-152926-101426-5ef5a0/ in the ZIP.

Public sources (click IDs; full titles in the independent PDF): J1